

LEARNING RESOURCE GUIDE
ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional
Participant Workbook

Jurisdictional Differences and Privacy Impact Assessments (PIA)

1. Learning Objectives

By the end of this lecture, you will be able to:

- Explain how conflicting national privacy laws create jurisdictional complexity for multinational cloud deployments.
- Describe ISO/IEC 27018 and GAPP as frameworks that help organisations manage privacy obligations in the cloud.
- Explain how GDPR adequacy decisions and Standard Contractual Clauses function as transfer mechanisms for personal data.
- Define a Privacy Impact Assessment (PIA) and identify when one is required and what it must address.
- Apply the PIA process to a cloud migration scenario, identifying the privacy risks and mitigation options it surfaces.

2. Introduction

A multinational retail conglomerate headquartered in Germany operates stores in 28 countries and runs its customer loyalty programme on a cloud platform with compute nodes in the United States, Singapore, and Ireland. The platform processes personal data about customers in every country where the company operates. During a routine compliance review, the legal team realised it had never formally mapped the data flows between cloud regions. The GDPR team assumed SCCs covered all non-EU transfers. The Singapore team assumed local data residency requirements were met. The US team had no visibility into what data passed through its region. Each team had a piece of the puzzle. None had the full picture.

This scenario is not unusual. As organisations build cloud architectures across jurisdictions, the regulatory picture becomes fragmented. A single transaction can trigger obligations under GDPR in Europe, data localisation laws in a specific country, sector-specific privacy rules in another jurisdiction, and government access provisions in a third. Managing this complexity requires both frameworks that provide reference points across jurisdictions and structured processes — like PIAs — that force organisations to ask the right questions before they build.

This lecture covers both. The first half addresses jurisdictional tools: ISO/IEC 27018, GAPP, adequacy decisions, and Standard Contractual Clauses. The second half works through the PIA process as a structured mechanism for identifying and mitigating privacy risk in cloud environments before systems are deployed.

3. Core Concepts Explained

Jurisdictional Conflict in Cloud Environments

When an organisation stores data in the cloud, that data may be replicated across multiple regions, processed in data centres in several countries, and accessed by administrators in yet another location. Each location may carry its own legal framework governing data handling, retention, access by government authorities, and transfer conditions. The combination creates genuine legal conflict.

GDPR requires that personal data about EU residents not be transferred to countries without adequate protections or appropriate safeguards. China's Personal Information Protection Law restricts cross-border transfers of data collected within China. Russia's data localisation law requires certain data about Russian citizens to be stored on Russian servers. The United States does not have a single federal privacy law but applies a patchwork of sector-specific and state laws, with California's CPRA being among the most significant.

A multinational organisation running workloads on a global cloud provider may be subject to all of these regimes simultaneously. The data flowing through its systems may be subject to different rules depending on where each individual whose data it processes happens to be located. Identifying which rules apply — and ensuring the architecture reflects them — is one of the core privacy engineering challenges in cloud security.

ISO/IEC 27018: PII Protection in the Public Cloud

ISO/IEC 27018 is a standard developed specifically for cloud service providers to address the protection of personally identifiable information in public cloud environments. It extends ISO/IEC 27001's information security management system with additional controls focused on PII handling. Key requirements include: obtaining consent before using customer data for marketing purposes; clearly disclosing to customers where their data is processed; maintaining procedures for responding to data subject access requests; and ensuring that data is not used for purposes beyond those agreed with the customer.

For cloud customers evaluating provider privacy posture, ISO/IEC 27018 certification provides a meaningful signal. It indicates the provider has been independently assessed against a set of PII-specific controls that go beyond general information security management. When evaluating cloud providers for deployments involving personal data, ISO/IEC 27018 certification is one of the key indicators to look for alongside SOC 2 Type II reports and ISO/IEC 27001 certificates.

Generally Accepted Privacy Principles (GAPP)

GAPP was developed jointly by the American Institute of CPAs and the Canadian Institute of Chartered Accountants as a reference framework for building privacy programmes. It comprises ten privacy principles: management, notice, choice and consent, collection, use and retention, access, disclosure to third parties, security, quality, and monitoring and enforcement.

GAPP is not a law. It does not carry the force of GDPR or HIPAA. Its value lies in providing a structured, internationally recognised framework for assessing an organisation's privacy programme against a consistent set of principles. It maps well to many regulatory requirements and is widely used by audit and advisory teams performing privacy programme assessments. For the CCSP exam, GAPP appears as a framework-level reference, contrasted with jurisdiction-specific regulatory requirements.

GDPR Adequacy Decisions

The European Commission can determine that a third country provides an adequate level of data protection. Where an adequacy decision exists, personal data can flow from the EU to that country without additional safeguards being required. Countries with adequacy decisions include Japan, Canada (for commercial organisations under PIPEDA), the United Kingdom, Switzerland, and New Zealand, among others. The United States does not hold a blanket adequacy decision. Instead, the EU-US Data Privacy Framework provides a transfer mechanism for certified US organisations.

Adequacy decisions can be withdrawn — as occurred when the Court of Justice of the European Union invalidated both Safe Harbor in 2015 and Privacy Shield in 2020 following legal challenges. Organisations that relied on these mechanisms had to find alternatives rapidly. This history illustrates why understanding the full range of transfer mechanisms — not just the current one — is important for long-term cloud architecture planning.

Standard Contractual Clauses and Binding Corporate Rules

When no adequacy decision exists, the most common mechanism for GDPR-compliant international data transfers is Standard Contractual Clauses. SCCs are template contracts approved by the European Commission that create binding data protection obligations between the exporting and importing parties. They are updated periodically — new modular SCCs were issued in 2021 to reflect the GDPR framework — and must be incorporated into contracts without substantive modification.

Binding Corporate Rules serve a similar function for intra-group transfers within multinational organisations. BCRs allow a company to transfer personal data among its own subsidiaries globally, provided the BCRs have been approved by the relevant supervisory authority and bind all group entities to GDPR-equivalent protections. BCRs are expensive and time-consuming to obtain but provide a durable, scalable solution for large multinationals with significant internal data flows.

The key principle for CCSP purposes: international data transfers from the EU are a regulated act. Every transfer must be assessed, and an appropriate mechanism must be in place before data flows across borders. Cloud architecture decisions — which region hosts which data, which provider processes which records — have direct legal consequences that must be addressed before deployment.

Privacy Impact Assessments (PIAs)

A Privacy Impact Assessment — called a Data Protection Impact Assessment or DPIA under GDPR — is a structured process for identifying and evaluating the privacy risks associated with a new project, system, process, or technology before it is deployed. The goal is to catch privacy problems at the design stage, when changes are inexpensive, rather than after a system is in production, when they are costly and sometimes impossible.

Under GDPR, a DPIA is mandatory when processing is likely to result in a high risk to individuals. High-risk processing includes: large-scale processing of sensitive data categories; systematic monitoring of publicly accessible areas; the use of new technologies that may pose significant risks; and automated decision-making with significant legal or similarly significant effects on individuals. Many other frameworks require PIAs in analogous circumstances. The US E-Government Act of 2002 requires federal agencies to conduct PIAs for any system collecting personally identifiable information. Quebec's Law 25 requires PIAs before certain technology projects involving personal data.

Even when not strictly required, a PIA is good practice. Consider a cloud migration scenario: an organisation moving a human resources database to a cloud provider. That database contains employee personal information, performance records, and payroll data. A PIA before the migration would work through a structured set of questions: What personal data is involved? What is the purpose of the processing? Is the data proportionate to that purpose? What are the risks to individuals if the data is breached, lost, or misused? What controls are in place to mitigate those risks? Does the architecture comply with applicable law, particularly for any international data transfers?

What a PIA Produces

The output of a PIA is not merely a checklist. It is a documented risk assessment that may result in changes to the project scope or technical design. A PIA might produce: requirements for additional encryption or key management; access control restrictions reducing the number of parties who can view sensitive data; reduced data retention periods; data minimisation requirements that limit what fields are collected; or, in some cases, a documented decision not to proceed with a particular cloud deployment at all.

For the CCSP exam, PIAs are positioned as a proactive privacy control applied at the design stage. They help organisations demonstrate accountability to regulators — showing that privacy risk was considered before building, not after a breach occurred. In cloud contexts, PIAs frequently surface risks unique to shared infrastructure: data co-mingling across tenants, data residency uncertainty, provider access to data during processing, and unclear sub-processor chains.

4. Jurisdictional Transfer Mechanisms: Comparison Table

Mechanism	Applicability	Key Characteristic
Adequacy Decision	Countries formally approved by European Commission	Free flow of personal data permitted without additional safeguards; can

		be withdrawn
Standard Contractual Clauses (SCCs)	Transfers to non-adequate third countries	Approved template contract; must be incorporated without substantive modification
Binding Corporate Rules (BCRs)	Intra-group transfers within multinationals	Approved by supervisory authority; binds all group entities to GDPR-equivalent protections
EU-US Data Privacy Framework	Transfers to certified US organisations	Replaces Privacy Shield; requires US organisation certification and annual recertification

5. Real-World Incident

Case Study: The invalidation of the EU-US Privacy Shield by the Court of Justice of the European Union in July 2020 (Schrems II) immediately disrupted transatlantic data flows for thousands of organisations. Privacy Shield had been the primary transfer mechanism for personal data between the EU and the US since 2016. The court found that US surveillance laws did not provide EU individuals with effective redress against government access to their personal data. Overnight, organisations relying solely on Privacy Shield had no valid transfer mechanism and faced regulatory exposure. Many scrambled to execute Standard Contractual Clauses — but the court also required organisations to assess whether SCCs were sufficient given US law. The incident demonstrated that no transfer mechanism should be treated as permanent infrastructure. Organisations that had maintained SCCs alongside Privacy Shield faced significantly less disruption than those that had not.

6. Analogy

Think of a PIA as a building inspection before the walls go up. Once concrete is poured and steel is framed, structural changes become enormously expensive. The inspection catches design flaws — inadequate load-bearing, insufficient fire exits — before they become permanent. A PIA performs the same function for data: it identifies privacy risks when the system is still a blueprint, when changing the data model, the access controls, or the vendor relationship costs a fraction of what it would after deployment. Regulators regard a completed PIA as evidence that the organisation thought about privacy before it built, not after it failed.

7. Exam Focus

For the CCSP exam, jurisdictional complexity and PIAs appear in scenario questions requiring identification of the correct transfer mechanism, assessment framework, or privacy control for a described situation. Key points to retain:

- ISO/IEC 27018 is a PII-specific extension of ISO/IEC 27001 designed for cloud providers — not a general information security standard.

- GAPP is a framework, not a law. It is used for privacy programme assessment but does not carry regulatory enforcement.
- Adequacy decisions can be revoked. Organisations must have contingency transfer mechanisms, not just the currently applicable one.
- SCCs are the most operationally common GDPR transfer mechanism for non-adequate countries. They must be incorporated without modification.
- BCRs are used for intra-group transfers and require supervisory authority approval. They are expensive to obtain but durable.
- A DPIA under GDPR is mandatory for high-risk processing, including large-scale sensitive data processing and new technologies with significant individual impact.
- PIAs are a design-stage control: proactive, not reactive. They appear in questions about when to assess privacy risk, not how to respond to a breach.
- The PIA process addresses: data involved, purpose, proportionality, risks to individuals, and mitigating controls.
- The CCSP exam may test the distinction between when a DPIA is mandatory under GDPR versus when it is good practice.

8. Key Terms Glossary

ISO/IEC 27018: An international standard extending ISO/IEC 27001 with PII-specific controls for cloud service providers processing personally identifiable information.

GAPP (Generally Accepted Privacy Principles): A ten-principle framework developed by AICPA and CPA Canada for building and assessing privacy programmes; not a law.

Adequacy Decision: A European Commission determination that a third country provides a level of data protection equivalent to GDPR, permitting free data flows without additional safeguards.

Standard Contractual Clauses (SCCs): European Commission-approved template contracts providing a legal basis for transferring personal data from the EU to non-adequate third countries.

Binding Corporate Rules (BCRs): An intra-group data transfer mechanism for multinationals, approved by a supervisory authority, binding all group entities to GDPR-equivalent protections.

Privacy Impact Assessment (PIA): A structured process for identifying and evaluating privacy risks associated with a new system or process, conducted before deployment.

DPIA (Data Protection Impact Assessment): GDPR's term for a mandatory PIA required when processing is likely to result in high risk to individuals' rights and freedoms.

Data Localisation: A legal requirement to store or process certain data on servers physically located within a specified country or jurisdiction.

Data Residency: The requirement or policy governing in which geographic location data is stored, often driven by regulatory, contractual, or sovereignty considerations.

EU-US Data Privacy Framework: The transfer mechanism established in 2023 enabling certified US organisations to receive personal data from the EU, replacing the invalidated Privacy Shield.

9. Quick Revision Checklist

- ☐ I can explain why multinational cloud environments create jurisdictional complexity for personal data transfers.
- ☐ I know what ISO/IEC 27018 certifies and why it is relevant when evaluating cloud provider privacy posture.
- ☐ I can describe GAPP and explain that it is a framework, not a law.
- ☐ I know the difference between an adequacy decision and Standard Contractual Clauses as data transfer mechanisms.
- ☐ I understand that adequacy decisions can be invalidated and that organisations should maintain contingency transfer mechanisms.
- ☐ I can explain when a DPIA is mandatory under GDPR versus when it is good practice.
- ☐ I know the core questions a PIA must address: data involved, purpose, proportionality, risks to individuals, and controls.
- ☐ I understand that PIAs are a design-stage control, not a post-breach response.
- ☐ I can distinguish BCRs from SCCs and identify which is used for intra-group versus third-party transfers.
- ☐ I know that PIAs may result in project changes including encryption requirements, access restrictions, or in some cases a decision not to proceed.

10. Practice MCQs

Question 1

SCENARIO: A global financial services firm runs its customer analytics platform on a cloud provider with nodes in the United States, Ireland, and Singapore. The firm processes personal data about customers in the EU, US, and Southeast Asia. The legal team discovers that data of EU residents is being replicated to the US node for performance reasons, but no data transfer mechanism has been put in place for this flow. Which of the following most accurately describes the firm's immediate compliance gap?

A) The firm must obtain explicit consent from each EU customer for the US data transfer.

Explanation: Incorrect. Consent is a valid GDPR transfer mechanism but is impractical for large-scale, ongoing operational transfers. Consent must be specific, informed, and freely withdrawable — making it unsuitable as the primary mechanism for replication flows.

B) The firm is transferring personal data about EU residents to a non-adequate country without a valid transfer mechanism, violating GDPR Article 44.

Explanation: Correct. Any transfer of EU personal data to a non-adequate third country must be covered by an approved mechanism such as SCCs, BCRs, or an adequacy decision. Without one, the transfer violates GDPR Article 44 regardless of the business reason.

C) The firm needs to obtain ISO/IEC 27018 certification for its US node to authorise the data transfer.

Explanation: Incorrect. ISO/IEC 27018 is a provider certification standard that signals PII controls are in place. It is not a legal transfer mechanism under GDPR. Certification alone does not authorise cross-border personal data transfers.

D) The firm must cease the US replication entirely because the United States has no adequate data protection laws.

Explanation: Incorrect. While the US lacks a blanket adequacy decision, transfers to the US are permitted using SCCs, BCRs, or the EU-US Data Privacy Framework for certified organisations. Ceasing replication is not the only or required response.

Question 2

SCENARIO: An organisation is designing a new cloud-based HR system that will process employee performance reviews, payroll data, and disciplinary records for 45,000 employees across the EU. The system will use an algorithm to generate performance rankings. Which of the following best describes the organisation's GDPR obligations before deploying this system?

A) The organisation must conduct a DPIA because the processing involves large-scale data of EU employees and includes automated decision-making with significant effects.

Explanation: Correct. Large-scale processing of employee data combined with automated decision-making with significant legal or similarly significant effects on individuals triggers the mandatory DPIA requirement under GDPR Article 35.

B) A DPIA is optional because employee data is less sensitive than health or biometric data.

Explanation: Incorrect. Employee performance, payroll, and disciplinary data is personal data under GDPR. The mandatory DPIA trigger is not limited to special categories of data — large-scale processing and automated decision-making with significant effects independently trigger the requirement.

C) The organisation must obtain individual consent from each employee before deploying the system.

Explanation: Incorrect. Consent is not the appropriate legal basis for processing employee data in most employment contexts, where consent cannot be freely given due to the power imbalance. The lawful basis for employment-related processing is typically contractual necessity or legitimate interest.

D) A DPIA is only required if the system processes health or biometric data.

Explanation: Incorrect. GDPR Article 35 specifies multiple triggers for mandatory DPIAs,

including large-scale processing and automated decision-making with significant effects. The trigger is not limited to special categories of sensitive data.

Question 3

Which of the following most accurately describes the role of Standard Contractual Clauses in GDPR compliance?

A) SCCs are negotiable template agreements that organisations may modify to reflect commercial arrangements with cloud providers.

Explanation: Incorrect. SCCs must be incorporated into contracts without substantive modification. Modifying the clauses may invalidate them as a transfer mechanism and expose the organisation to regulatory action.

B) SCCs are European Commission-approved template contracts that provide a legal basis for personal data transfers from the EU to non-adequate third countries.

Explanation: Correct. SCCs provide a contractual mechanism for GDPR-compliant data transfers where no adequacy decision exists. They bind both parties to data protection obligations consistent with GDPR requirements.

C) SCCs apply only to transfers between EU member states and countries with no privacy laws.

Explanation: Incorrect. SCCs apply to any transfer to a country outside the EU/EEA that lacks an adequacy decision, regardless of whether that country has its own privacy laws.

D) SCCs exempt the data exporter from liability for breaches occurring at the data importer's facilities.

Explanation: Incorrect. SCCs do not exempt the exporter from liability. Both parties assume contractual obligations, and the data exporter may face regulatory action if the importer fails to protect the data as required.

Question 4

What is the primary distinction between ISO/IEC 27018 and ISO/IEC 27001 in the context of cloud privacy?

A) ISO/IEC 27001 applies only to cloud providers, while ISO/IEC 27018 applies to all types of organisations.

Explanation: Incorrect. ISO/IEC 27001 applies to any organisation with an ISMS. ISO/IEC 27018 is the standard specifically developed for cloud service providers handling PII.

B) ISO/IEC 27018 extends ISO/IEC 27001 with PII-specific controls for cloud service providers, addressing issues such as consent, disclosure of processing locations, and data subject access.

Explanation: Correct. ISO/IEC 27018 was developed specifically to add privacy controls for personally identifiable information on top of the general information security controls in ISO/IEC 27001, with requirements tailored to the public cloud context.

C) ISO/IEC 27018 is a legal compliance standard that can substitute for GDPR compliance.

Explanation: Incorrect. ISO/IEC 27018 is a voluntary international standard, not a legal requirement. Certification does not substitute for GDPR compliance or constitute a legal basis for data transfers.

D) ISO/IEC 27018 applies to physical security controls in cloud data centres, while ISO/IEC 27001 covers logical security.

Explanation: Incorrect. Both standards address logical security controls. ISO/IEC 27018 adds PII-specific privacy controls for cloud providers — it is not limited to physical security.

Question 5

SCENARIO: An organisation conducts a PIA before migrating its customer database to a cloud provider. The PIA identifies that the cloud provider's default configuration replicates data to a secondary region in a different country that lacks an adequacy decision, and that the organisation's data retention settings have not been configured, meaning data is retained indefinitely. What is the most appropriate outcome of this PIA finding?

A) The organisation should proceed with migration and address the findings in the next annual audit cycle.

Explanation: Incorrect. PIA findings that identify active compliance failures — an invalid international transfer and unlimited retention — cannot be deferred to an audit cycle. They represent current obligations under GDPR that must be addressed before deployment.

B) The organisation should configure data residency settings to restrict replication, execute SCCs with the provider for any permitted cross-border flows, and implement a defined retention policy before proceeding with migration.

Explanation: Correct. The PIA has identified two specific gaps: a cross-border transfer without a valid mechanism and the absence of a retention policy. Both must be resolved before the system goes live. This is precisely what PIAs are designed to produce — actionable findings that change the technical configuration or contractual terms before deployment.

C) The provider's ISO/IEC 27001 certification covers both issues and no additional action is required.

Explanation: Incorrect. ISO/IEC 27001 certifies the provider's ISMS. It does not address the organisation's GDPR obligations for data transfers or retention. The responsibility remains with the data controller.

D) The findings are the cloud provider's responsibility to resolve under the shared responsibility model.

Explanation: Incorrect. Data residency configuration and retention policy settings are typically customer responsibilities under the shared responsibility model. The provider makes capabilities available; the customer configures them.

Question 6

Binding Corporate Rules (BCRs) are used to facilitate which type of personal data transfer?

A) Transfers from the EU to any third country by any organisation that obtains supervisory authority approval.

Explanation: Incorrect. BCRs are specifically designed for intra-group transfers — within a multinational organisation's own corporate family. They are not a general-purpose transfer mechanism for transfers to unrelated third parties.

B) Intra-group transfers within a multinational organisation, binding all group entities to GDPR-equivalent protections.

Explanation: Correct. BCRs allow a multinational to transfer personal data among its own subsidiaries globally, provided the BCRs have been approved by the relevant supervisory authority and bind all group entities.

C) Transfers between EU member states within the single market.

Explanation: Incorrect. Transfers within the EU/EEA do not require a separate transfer mechanism. GDPR applies uniformly within the EEA and does not restrict intra-EEA transfers.

D) Emergency transfers during a personal data breach where SCCs cannot be executed in time.

Explanation: Incorrect. Emergency situations are addressed through GDPR Article 49 derogations, not BCRs. BCRs are a planned, long-term intra-group transfer mechanism requiring advance supervisory authority approval.

Question 7

GAPP (Generally Accepted Privacy Principles) differs from GDPR in which fundamental way?

A) GAPP applies only to organisations in Canada, while GDPR applies globally.

Explanation: Incorrect. GAPP was developed jointly by US and Canadian accounting bodies and is used internationally as a reference framework. Neither GAPP nor GDPR is limited to Canada.

B) GAPP is a voluntary framework used for privacy programme assessment, while GDPR is a legally enforceable regulation.

Explanation: Correct. GAPP provides a structured set of ten principles for evaluating privacy programmes but carries no regulatory enforcement. GDPR is a directly applicable EU regulation with supervisory authority enforcement and significant financial penalties.

C) GAPP requires organisations to appoint a Data Protection Officer, while GDPR does not.

Explanation: Incorrect. GDPR Article 37 requires DPO appointment for certain categories of processing. GAPP does not specify a DPO requirement.

D) GAPP applies specifically to cloud service providers, while GDPR applies to all organisations.

Explanation: Incorrect. GAPP applies to any organisation with a privacy programme.

ISO/IEC 27018 is the standard specifically developed for cloud service providers. GDPR applies to any organisation processing EU personal data.

Question 8

During a PIA, a cloud security architect discovers that the proposed system would allow the cloud provider's support staff to access unencrypted customer data when performing maintenance tasks. Which PIA outcome best addresses this finding?

A) Document the finding and proceed; provider access during maintenance is a standard cloud service condition.

Explanation: Incorrect. Undocumented or excessive provider access to unencrypted customer data represents a real privacy risk. Documenting and accepting it without control changes fails the purpose of the PIA, which is to mitigate identified risks.

B) Implement application-layer encryption with customer-managed keys so that provider support staff access only encrypted data, or contractually restrict provider access to defined, logged scenarios.

Explanation: Correct. The PIA has identified a risk: provider access to clear-text data. Appropriate mitigations are technical (customer-managed encryption preventing access to plain text) or contractual and technical (restricting and logging support access). Both address the identified risk.

C) Require the provider to sign a NDA covering all data accessed during maintenance.

Explanation: Incorrect. NDAs address confidentiality obligations contractually but do not prevent access or provide technical protection. They do not mitigate the underlying privacy risk of unencrypted data exposure.

D) Move the system to an on-premises deployment to eliminate provider access entirely.

Explanation: Incorrect. While on-premises deployment eliminates provider access, it is not the proportionate or required response to this finding. Technical controls such as customer-managed encryption address the risk without abandoning cloud benefits.

Question 9

Which of the following is NOT a trigger for a mandatory DPIA under GDPR Article 35?

A) Systematic and extensive evaluation of personal aspects of individuals based on automated processing, including profiling, that produces significant effects.

Explanation: Incorrect. This is explicitly listed in GDPR Article 35(3)(a) as a mandatory DPIA trigger.

B) Processing of personal data relating to a small number of individuals by an organisation with fewer than 50 employees.

Explanation: Correct. Organisation size and data volume alone do not trigger a mandatory DPIA. The triggers are based on risk to individuals — high-risk processing categories — not on the number of employees or the quantity of records processed.

C) Large-scale processing of special categories of personal data such as health, biometric, or racial origin data.

Explanation: Incorrect. Large-scale processing of special categories is explicitly listed as a mandatory DPIA trigger under GDPR Article 35(3)(b).

D) Systematic large-scale monitoring of a publicly accessible area.

Explanation: Incorrect. Systematic large-scale monitoring of publicly accessible areas such as CCTV in public spaces is explicitly listed as a mandatory DPIA trigger under GDPR Article 35(3)(c).

Question 10

SCENARIO: A CCSP candidate is reviewing a cloud deployment in which a US healthcare technology company processes personal data for EU-based clinical trial participants. The company relies on an adequacy decision that was issued three years ago but has since been under review. Which of the following represents the most prudent course of action?

A) Continue relying on the adequacy decision until it is formally withdrawn by the European Commission.

Explanation: Incorrect. Relying solely on an adequacy decision under active review creates regulatory exposure. If the decision is withdrawn, the transfer immediately loses its legal basis. Prudent organisations maintain contingency mechanisms.

B) Execute Standard Contractual Clauses alongside the adequacy decision as a contingency, ensuring a valid transfer mechanism remains in place if the adequacy decision is withdrawn.

Explanation: Correct. Maintaining SCCs as a parallel mechanism is the prudent approach when an adequacy decision is under review. If the decision is withdrawn, the SCCs provide immediate continuity of the transfer's legal basis. This lesson was reinforced by the Schrems II ruling, which left organisations relying solely on Privacy Shield without any valid mechanism overnight.

C) Transfer only anonymised data until the adequacy review is resolved.

Explanation: Incorrect. Anonymisation is one approach to removing GDPR applicability, but it is not the only or required response. If the organisation needs to process identifiable data for clinical trial purposes, anonymisation may not be technically or scientifically feasible. Parallel SCCs are a more practical solution.

D) Obtain ISO/IEC 27018 certification for the US facilities as an alternative transfer mechanism.

Explanation: Incorrect. ISO/IEC 27018 is a provider certification standard. It is not a legal transfer mechanism under GDPR Article 44 and cannot substitute for an adequacy decision or SCCs.